

Experiment 6: Risk Treatment and Risk Acceptance

Aim

To manage identified business risks by defining suitable risk treatment plans and documenting risk exceptions using the Eramba GRC dashboard.

Procedure

1. Login to the Eramba Dashboard.
2. Navigate to **Risk Management** → **Business Risks**.
3. Select the **Business Interruption** risk.
4. Open the **Analysis** section and verify the risk assessment.
5. Review the Likelihood, Impact, and Risk Score.
6. Open the **Treatment** section.
7. Configure the risk treatment as **Accept** and associate relevant internal controls such as *Endpoint Protection*, *Backup and Recovery*, and *Firewall Management*.
8. Associate the *Information Security Policy* with the treatment.
9. Save the risk treatment configuration.
10. Navigate to **Risk Management** → **Risk Exceptions**.
11. Create/import risk exceptions with a description, requester, contact, expiration date, and status.
12. Verify the created exceptions in the Risk Exceptions register.

Output

The Business Interruption risk was analyzed with a Medium Likelihood, Very High Impact, and Risk Score of 6. Relevant controls and the Information Security Policy were associated with the risk treatment. 10 risk exceptions were also created and recorded in Eramba.

The screenshot displays the 'Edit Action' window for a risk analysis configuration. It features three tabs: 'General', 'Analysis', and 'Treatment'. The 'Analysis' tab is active, showing a form with the following fields: 'Likelihood (Medium)' with a dropdown arrow, 'Impact (Very High)' with a dropdown arrow, and 'Risk Score' with a dropdown arrow. Below these fields, there are three sections for associated controls: 'Associated Controls (1)' with a list of controls, 'Associated Policies (1)' with a list of policies, and 'Associated Exceptions (1)' with a list of exceptions. At the bottom right, there are 'Close' and 'Save' buttons.

Fig 6.1 – Risk Analysis Configuration (Likelihood: Medium, Impact: Very High, Score: 6)

Edit Action

General

Analysis

Treatment

Risk Treatment

Accept

Search for control treatments for this risk

Mitigating Business Continuity Plans

Choose one to work...

add

No results found

Endpoint Protection

Backup and Recovery

Firewall Management

add

Treatment Policies

Information Security Policy (Policy)

add

Treatment Risk Exceptions

add

Cancel

Save

Item detail

General

Dynamic Status

Name

Business Interruption

Description

A disruptive event may prevent critical business processes from operating normally.

Risk GRC Contact

Admin Admin

Risk Originator Contact

Admin Admin

Next Review Date

2027-06-27

Analysis

Applicable Business Units

Operations

Processes

Threat Tags

Threat Description

Vulnerability Tags

Vulnerability Description

Risk Analysis Classification

Low/Medium/Medium Impact/Very High

Risk Analysis Score

0

Risk Analysis Threshold

Treatment

Risk Treatment

Accept

Mitigating Business Continuity Plans

Treatment Internal Controls

Endpoint Protection

Backup and Recovery

Firewall Management

Treatment Policies

Information Security Policy

Treatment Risk Exceptions

Treatment Projects

Fig 6.5 – Risk Treatment Summary (Accept & Internal Controls)

Risk Response Plan	
Risk Treatment Classification	Likelihood (Medium) Impact (Very High)
Risk Treatment Score	6
Risk Treatment Threshold	

[illegible]

The screenshot shows the 'Reputation Damage Risk Exception' form. The form is titled 'Reputation Damage Risk Exception' and has a 'Save' button. The form contains the following fields:

- Name:** Reputation Damage Risk Exception
- Description:** Reputation exception for reputation damage risk while performing marketing activities and outreach.
- SEO Channel:** Search engine
- Reputation Manager Contact:** Search engine
- Status:** Draft
- Start Date:** 05/20/2016 10:17
- Expiration Date:** 05/20/2016 10:17
- Channel Code:** (empty)
- Account Email Address:** (empty)

At the bottom of the form, there is a 'Submit' button and a 'View History' link.

Result

The business risk was successfully analyzed and its treatment was configured in Eramba. Risk exceptions were successfully created, configured with requesters, contacts, and expiration dates, and verified in the Risk Exceptions register.